Control Area	Android Steps	iOS Steps	Example / Notes
App Vetting	Google Play → "About this app" → Check developer, last update, permissions	App Store → App Privacy → Review data types collected	Only install apps requesting permissions relevant to their function
Install Source Enforcement	Settings → Security → Verify apps (Play Protect) → Disable "Unknown sources"	N/A (App Store–only on non-jailbroken devices)	Prevents sideloading of potentially malicious APKs
Runtime Permission Management	Settings → Apps → [App] → Permissions → Allow / Ask / Deny	Settings → Privacy & Security → [Category] → Set to Never / Ask Next Time / While Using	Granular control over camera, mic, location, contacts, etc.
Auto-Revoke Unused Permissions	Settings → Apps → Special access → Unused apps → Enable	N/A	Android can remove permissions from apps you haven't opened in months
Sandbox & Container Isolation	Use Android Enterprise work profile or Island app profile	Deploy managed apps via MDM with per-app VPN & DLP	Keeps sensitive corporate or high-risk apps isolated from personal data
Per-App Network Controls	Install NoRoot Firewall or AFWall+ → Set allow/deny rules per app	Install VPN-based firewalls (Lockdown, Guardian Firewall) → Whitelist/blacklist per app	Blocks unwanted outbound connections and prevents data exfiltration
Secure App Development Practices	Manifest: declare only needed permissions; Use EncryptedFile API	Info.plist: include only necessary entitlements; Use NSFileProtectionComplete	Reduces attack surface and ensures on-disk data encryption

in the app's .entitlements file – only explicit capabilities are allowed (e.g., HealthKit, HomeKit).

- **User Tip:** Only grant entitlements you need; for example, disallow background audio if the app doesn't intend to play music.

Work profiles and managed app containers

1. Android work profile

- Using Android Enterprise or apps like Island, create a separate "Profile" that isolates corporate apps and data from personal apps.

2. iOS managed containers

- Via MDM, deploy managed apps that store data in encrypted containers; you can remotely wipe these containers without affecting personal apps.

Example: An Enterprise employee uses a Work Profile for Slack and corporate email; switching to Personal Profile immediately locks corporate data behind a PIN.

Secure app development practices

Organizations building or distributing apps must follow best practices to minimize permission-related risks.

1. Define minimal permission sets

- Specify only the essential permissions in your manifest or Info.plist, per Android's Security Tips.

2. Runtime permission testing

- Test all permission combinations: granted, denied, or revoked